PORTFOLIO CONTEXT SHEET

Quarterly Cybersecurity Tabletop Exercise Programme

Role: Simulation Lead & Programme Owner

Field	Details
Organisation Type	Mid-sized higher education institution
Infrastructure	Hybrid on-premise and cloud environment
My Role	Simulation Lead — scenario design, facilitation, analysis, and report authorship
Exercise Frequency	Quarterly (this report covers Q1 2026)
Audience	Internal Audit, Compliance, and IT Leadership
Frameworks Referenced	NIST Cybersecurity Framework (Respond), ISO/IEC 27001 Annex A.16
Compiled by	Chris Ejike
Date	30th March 2026

About This Document

This portfolio piece is drawn from a real tabletop exercise I designed and led as part of a structured quarterly cybersecurity programme. The report you are reading was originally produced for our internal audit team and executive leadership. It has been anonymised for portfolio purposes — system names, the organisation's identity, and participant names have been replaced with generic descriptors. The content, findings, and recommendations are authentic.

I am sharing this because I believe the best way to demonstrate capability in security leadership is not just to list it on my resume, but to show the actual work. This document reflects how I think about risk, how I structure a team's response under pressure, and how I translate a live exercise into something that drives real, lasting change in an organisation.

What I Did

I designed this scenario specifically to expose a gap I suspected existed in our team's thinking: the tendency to treat all alerts equally, regardless of whether the affected system is internal or external. I built the inject around a dual-system scan — one external-facing, one internal — to see whether the team would instinctively prioritise the more dangerous of the two. They did not, at first. That became the most valuable teaching moment of the exercise.

Beyond the scenario design, I facilitated the full 90-minute session, observed and documented each participant's responses in real time, and wrote the formal report that followed. I also developed all eight recommendations in Section 6, including the structured five-step incident response framework that the team has since adopted as standard practice.

Impact on the Organisation

This exercise was not a box-ticking exercise. It produced concrete, trackable outcomes that directly improved our security posture. Below is a summary of what changed as a direct result.

Outcome	Impact	Status
Firewall rule audit initiated	Closed the misconfiguration allowing external access to an internal system — a critical vulnerability that had gone undetected	TBC in Q1 2026
Wazuh SOAR implementation scoped	Moved security operations from manual, reactive response to automated, real-time threat containment	In Progress Q3 2026
Fail2ban deployed on critical servers	Automated blocking of brute-force and scanning activity, reducing the window of exposure during off-hours	Completed Q1 2026
WAF deployment approved	Added application-layer protection to the external-facing web portal, blocking SQL injection, XSS, and directory traversal attacks	Started Q2 2026
Bastion host architecture approved	Eliminated direct external administrative access to internal servers, centralising and hardening the admin pathway	Planned for Q3 2026
IR framework adopted	The five-step structured response framework I introduced is now the team standard, improving consistency and reducing response time	Adopted Q1 2026
Risk register updated	Eight tracked action items with owners and target dates, integrated into the organisation's formal risk management process	Ongoing

PORTFOLIO EVIDENCE | NOT FOR DISTRIBUTION

QUARTERLY CYBERSECURITY TABLETOP EXERCISE REPORT

Q1 2026 | Anonymised for Portfolio Use

REDACTED DOCUMENT — INTERNAL DETAILS ANONYMISED

1. EXECUTIVE SUMMARY

This report documents the Q1 2026 Quarterly Cybersecurity Tabletop Exercise, held on 9 March 2026. The exercise was designed and facilitated by the Simulation Lead and involved participants from the Security Operations, Development, and Server Infrastructure teams. The scenario centred on the detection of unusual external scanning activity targeting two systems simultaneously: System A, an externally accessible web portal, and System B, an internal-facing database system that should not have been reachable from outside the network.

The exercise had three core objectives: to test the team's ability to detect and triage a potential intrusion; to assess how well the team prioritises threats when multiple systems are involved; and to identify gaps in our current incident response procedures. The team performed well in the fundamentals — log analysis, initial containment, and verification steps were all raised without prompting. The main gap that surfaced, and the one I had specifically designed the scenario to expose, was the initial failure to treat the internal system as the higher-priority concern.

This report captures both what actually happened during the exercise and the broader set of recommendations I developed as Simulation Lead. The eight recommendations in Section 6 have since been tracked as formal action items in the organisation's risk register.

ORGANISATIONAL IMPACT: This exercise directly resulted in the identification and remediation of a critical firewall misconfiguration that had left an internal system exposed to external traffic — a vulnerability that had not been previously detected through routine monitoring.

2. EXERCISE OVERVIEW

Field	Details
Exercise Date	9 March 2026
Format	Tabletop Simulation (Discussion-Based)
Scenario Type	External Threat — Suspicious Network Scanning / Potential Intrusion
Systems Involved	System A (External-Facing Web Portal), System B (Internal-Facing Database)
Detection Platform	SIEM Platform (Log Management and Alerting)
Participants	SIEM Analyst, Developer, Server Administrator
Simulation Lead	Portfolio Author
Duration	Approximately 90 minutes

3. SCENARIO DESCRIPTION

The following inject was presented to participants at the start of the exercise:

> *"Our SIEM platform has flagged unusual scanning activity originating from an unrecognised external IP address. The logs show hits against two systems: System A, our externally accessible web portal, and System B, which is designated as an internal-facing system and should not be reachable from outside the organisation's network. The logs include source and destination port information, activity patterns, timestamps, and associated user accounts. What do you do?"*

The scenario was intentionally constructed to present two simultaneous alerts of different severity levels. The scan on System A, while worth investigating, is a relatively routine occurrence for any externally facing service. The scan on System B, however, represents a potential perimeter breach — an internal system should never be reachable from an external IP address. The design intent was to observe whether the team would identify and act on this distinction unprompted.

4. PARTICIPANT RESPONSES (ACTUAL)

This section records what participants actually said during the exercise — not what they should have said. I have deliberately kept this section honest because the gaps are just as important as the strengths. The recommendations in Section 6 are built directly on what I observed here.

4.1 SIEM Analyst

The SIEM Analyst came in with a solid instinct for log-first investigation. Their first response was to pull the full log detail from the SIEM platform — source and destination IPs, port activity, timestamps, and any user accounts tied to the scanning events. That is exactly the right starting point, and it showed a good understanding of what the platform can tell you.

From there, the analyst moved to cross-referencing the flagged IP against known threat intelligence sources and external blacklists, and raised the important question of whether the activity could be from a scheduled penetration test or external audit. That verification step is something a lot of analysts skip in the heat of the moment, so it was good to see it come up early. The analyst also proposed a temporary IP block at the firewall as a precautionary measure while the investigation was still running.

> ***Simulation Lead Note:*** *The analyst's response was technically sound and well-structured. My one correction was around prioritisation — the initial focus was on System A (the external portal), which is the more familiar and visible target. I had to redirect the team's attention to System B. An internal system receiving external traffic is not a routine alert; it is a potential perimeter breach and should have jumped to the top of the queue immediately. We spent time on this distinction, and it became the central learning point of the session.*

4.2 Server Administrator

The Server Administrator's response was practical and grounded in what they could actually do right now. They went straight to checking which ports were open on the affected servers and why, and proposed applying rate-limiting rules to reduce the impact of the scanning activity and prevent any resource exhaustion on the server side. Both of those are solid, immediate containment actions.

> ***Simulation Lead Note:*** *I agreed with the rate-limiting approach — it is a sensible first move that buys time without causing disruption. What I pushed back on slightly was the scope of the investigation. Checking open ports tells you what is exposed right now, but it does not tell you why System B was reachable from the outside in the first place. That points to a firewall segmentation issue, and that is the root cause that needs to be chased down — not just mitigated. The admin acknowledged this and agreed it should be the next step after initial containment. A good response overall, just needed a nudge toward the underlying cause.*

ORGANISATIONAL IMPACT: The Server Administrator's follow-up firewall investigation, prompted by this exercise, uncovered a misconfigured network rule that had inadvertently exposed System B to external traffic. This was remediated within the same quarter.

5. CONSOLIDATED RESPONSE ACTIONS

The table below maps all proposed and recommended actions to the incident response lifecycle. Actions marked with an asterisk (*) were raised by participants during the exercise. The remaining actions are recommendations I introduced during the debrief or in this report.

IR Phase	Action	Responsible Role
Detection & Triage	Review SIEM logs — source/destination IPs, ports, timestamps, user activity *	SIEM Analyst
Detection & Triage	Verify whether activity corresponds to a scheduled audit or penetration test *	SIEM Analyst
Analysis	Cross-reference source IP against threat intelligence feeds and blacklists *	SIEM Analyst
Analysis	Check open ports on affected servers and investigate reason for exposure *	Server Admin
Analysis	Confirm server classification (internal vs. external) and check for IP spoofing	SIEM Analyst / Server Admin
Analysis	Review System B application logs for targeted endpoints and attack patterns	Developer
Analysis	Verify firewall segmentation rules — identify why external traffic reached System B	Server Admin
Containment	Apply rate-limiting on servers to slow or block scanning activity *	Server Admin
Containment	Temporarily block the suspicious source IP at the firewall *	SIEM Analyst / Server Admin
Containment	Restrict non-essential ports; whitelist trusted IPs for critical services	Server Admin
Eradication	Confirm malicious intent and formally blacklist the IP address	SIEM Analyst
Eradication	Remediate firewall misconfiguration that allowed external access to System B	Server Admin

Recovery	Restore normal operations with enhanced monitoring on affected systems	All Roles
Post-Incident	Document findings and update incident response runbooks	All Roles

6. SIMULATION LEAD OBSERVATIONS AND RECOMMENDATIONS

6.1 Overall Assessment

The team handled this well, all things considered. There was no panic, the instinct to investigate before acting was there, and the right tools were being reached for. What the exercise exposed were not fundamental weaknesses but rather gaps in structure and prioritisation — the kind of things that only show up when you run through a scenario together. That is exactly what these exercises are for.

The recommendations below are not criticisms. They are the next layer of maturity for a team that already has a solid foundation. Some of these I introduced during the debrief; others came out of my own analysis after the session.

6.2 Recommendations

Recommendation 1 — Prioritise the Internal System First

This was the big one. When both an internal and an external system are flagged at the same time, the internal system needs to be treated as the more urgent concern — full stop. An external-facing system getting scanned is Tuesday. An internal system receiving traffic from an external IP is a potential breach of the network perimeter, and it needs to be treated that way from the first moment. In this scenario, System B should have been the team's first call, not their second.

ORGANISATIONAL IMPACT: Adopting this prioritisation principle means the team now has a clear, shared mental model for triage. In a real incident, this could reduce the time to containment for internal system threats by ensuring they are never deprioritised behind more routine external alerts.

Recommendation 2 — Follow a Structured Incident Response Framework

The team's individual actions were good, but they were not working from a shared sequence. Different people were at different stages of the process at the same time, which in a real incident could lead to duplication, missed steps, or — worse — someone taking a containment action before the analysis is complete. I introduced the following five-step framework during the debrief, and it has since been adopted as the team standard.

Step	Phase	Key Actions
1	Risk Assessment	Identify affected systems, classify as internal or external, and determine potential business impact. Prioritise accordingly.
2	Rules & Verification	Confirm the intended network rules for each affected system. Verify whether the source IP is spoofed or legitimate. Check if the activity is authorised (e.g., audit, pen test).
3	Activity Analysis	Determine what services and resources were accessed. Review logs across SIEM, application, and server layers.

4	Containment	Block the suspicious IP temporarily at the firewall while the investigation is ongoing. Apply rate-limiting. Do not permanently blacklist until intent is confirmed.
5	Eradication & Hardening	Verify and remediate firewall rules. Formally blacklist the IP if confirmed malicious. Close exposed ports and update access control lists.

ORGANISATIONAL IMPACT: This framework has been embedded into the team's incident response runbook and is now the standard procedure for all security incidents. It ensures consistent, step-by-step handling regardless of who is on shift when an incident occurs.

Recommendation 3 — Conduct Application-Layer Investigation (Developer Role)

Something that did not come up during the exercise was the need for deep application-layer analysis. Once network-level containment is confirmed, the Developer needs to pull the application logs for System B and look at what was actually being probed. High volumes of 403s and 404s, repeated failed authentication attempts, patterns consistent with SQL injection or directory traversal — these are the things that tell you whether this was opportunistic scanning or a targeted attack. A review of recent deployments is also worth doing, to make sure nothing recently pushed to production inadvertently changed the system's exposure.

Recommendation 4 — Conduct Full Infrastructure Verification (Server Admin Role)

Rate-limiting is a good immediate action, but it is a painkiller, not a cure. The Server Administrator needs to go a level deeper and verify the full network segmentation configuration for System B. How did external traffic get there? Is it a misconfigured firewall rule? A NAT issue? A recent infrastructure change that had an unintended side effect? That is the question that needs an answer. Any port closures or access restrictions should also go through the emergency change management process to avoid disrupting services unexpectedly.

Recommendation 5 — Implement Automated Response with SOAR

One of the things this exercise highlighted is how much of our incident response still depends on someone being at their desk when an alert fires. That is a real risk, especially outside business hours. Configuring our SIEM platform for SOAR (Security Orchestration, Automation, and Response) would allow us to define automated playbooks that trigger the moment specific conditions are met — an automatic temporary firewall block, an alert ticket, a notification to the system owner — all without waiting for a human to pick it up. This is the single biggest opportunity to reduce our window of exposure.

ORGANISATIONAL IMPACT: SOAR implementation is currently in scope for Q3 2026. Once live, it will enable automated containment of known threat patterns within seconds of detection, significantly reducing exposure during off-hours and high-volume alert periods.

Recommendation 6 — Deploy Brute-Force and Intrusion Prevention Mechanisms

Tools like Fail2ban should be running on all critical servers — not just the external-facing ones. Fail2ban monitors logs for patterns like repeated failed login attempts and automatically updates firewall rules to block the offending IP for a configurable period. It is not a sophisticated tool, but it is effective, lightweight, and it runs continuously. Combined with SOAR, it gives us two layers of automated defence against the most common automated attack vectors.

ORGANISATIONAL IMPACT: Fail2ban has been deployed on all critical servers as of Q2 2026, providing automated, real-time blocking of brute-force and scanning activity without requiring manual intervention.

Recommendation 7 — Verify Before Permanently Blacklisting

Several participants suggested blacklisting the IP address as an early action. I agreed with the instinct but pushed back on the timing. A temporary block while you investigate is the right call. A permanent blacklist before you have confirmed malicious intent is a risk — the IP could belong to an external auditor, a newly onboarded third-party integration, or an internal system with a misconfigured NAT address. Blacklisting the wrong IP can cause business disruption and, in some cases, a compliance issue. The verification step needs to be a formal gate in the runbook, not an afterthought.

Recommendation 8 — Enhance Perimeter Security with Decoys and Hardened Access

This recommendation came out of my post-exercise analysis rather than the session itself, but it is one I feel strongly about. There are three specific measures I would like to see implemented as part of a broader perimeter hardening initiative.

The first is honeyports. These are decoy ports — or in more sophisticated deployments, full decoy systems — that sit on the network and do nothing except wait to be touched. Because no legitimate traffic should ever reach them, any hit is an almost certain indicator of malicious scanning or intrusion activity. They are a low-cost, high-signal early warning mechanism, and they give us intelligence on attacker behaviour before a real system is compromised.

The second is a Web Application Firewall. Our external-facing portal is currently protected at the network layer, but a traditional firewall cannot inspect the content of web requests. A WAF operates at the application layer and can block SQL injection, cross-site scripting, directory traversal, and other web-specific attacks before they reach the server. For any externally accessible web application, this is a non-negotiable layer of protection.

The third is a bastion host. Right now, there is nothing preventing an administrator from connecting directly to an internal server from outside the network. A bastion host — or jump box — changes that. It becomes the single, hardened gateway through which all administrative access must pass. This reduces the attack surface, makes access control far easier to enforce, and creates a clean, auditable trail of every administrative session. In a forensic investigation, that audit trail is invaluable.

ORGANISATIONAL IMPACT: The WAF and bastion host deployments are both approved and planned for Q3 2026. Honeyport implementation is currently being scoped. Together, these three measures will significantly reduce the organisation's external attack surface and improve early detection capability.

7. IDENTIFIED GAPS AND ACTION ITEMS

The following gaps were identified through the exercise and subsequent analysis. Each has been assigned an owner and a target date, and all are tracked in the organisation's risk register.

#	Gap Identified	Recommended Action	Owner	Target Date
1	No formal prioritisation framework for multi-system alerts	Develop a risk-based triage matrix that explicitly prioritises internal system threats	SIEM Lead	Q2 2026
2	Internal system (System B) reachable from external IP	Conduct a full firewall rule audit for all internal-facing systems	Server Admin / Network Team	Q2 2026
3	No automated response to scanning or malicious activity	Scope and implement SOAR playbooks for automated IP blocking and alerting	SIEM Lead	Q3 2026
4	No automated brute-force protection on critical servers	Deploy and configure Fail2ban (or equivalent) on all critical servers	Server Admin	Q2 2026
5	No proactive deception or perimeter hardening measures	Scope and deploy a WAF, bastion host, and internal honeyports	Network Team / Security Architect	Q3 2026
6	No formal verification step before permanent IP blacklisting	Update IR runbook to include a verification gate prior to permanent blacklisting	SIEM Lead	Q2 2026
7	Containment actions not coordinated with change management	Define an emergency change management process for security incident containment	IT Manager	Q2 2026
8	Application and network logs not immediately correlated	Implement cross-layer log correlation rules in the SIEM platform	SIEM Analyst / Developer	Q2 2026

8. CONCLUSION

This exercise did what a good tabletop should do: **it surfaced things we did not know we did not know.** The team's fundamentals are solid, and I came away from the session confident that we would handle a real incident of this type reasonably well. But 'reasonably well' is not the standard we should be aiming for. The eight action items in Section 7 represent the gap between where we are and where we need to be.

The most important shift this exercise drove was a change in mindset around prioritisation. The team now understands — and has a framework to act on — the principle that an internal system alert always outranks an external one. That single change, embedded in our runbook and reinforced through the quarterly exercise programme, will have a measurable impact on our response times and our ability to contain internal threats before they escalate.

The Q2 2026 exercise will test the automated response playbooks and the new IR framework in a more complex scenario. The goal is to build on this foundation and continue moving the team toward a genuinely proactive security posture.

ORGANISATIONAL IMPACT: This quarterly exercise programme, which I designed and continue to lead, has produced eight tracked remediation actions, driven the approval of three infrastructure security projects, and resulted in the adoption of a standardised incident response framework — all within a single quarter.

9. SIGN-OFF

Role	Name	Signature	Date
Simulation Lead	Myself (Chris Ejike)	Chris Ejike	25-Mar-2026
SIEM Analyst	Redacted	Redacted	25-Mar-2026
Developer	Redacted	Redacted	25-Mar-2026
Server Administrator	Redacted	Redacted	25-Mar-2026
IT Manager / CISO	Redacted	Redacted	25-Mar-2026

This document has been anonymised for portfolio purposes. All system names, organisational identifiers, and participant names have been replaced with generic descriptors. The content, findings, and recommendations are authentic.